

Semana 3 — Objetivos de Aprendizado

Objetivos de Aprendizagem

Fundamentos de Redes

P: O que é rede e por que ela é essencial?

R: Redes conectam dispositivos para compartilhar recursos e dados, permitindo comunicação, colaboração e acesso a sistemas centralizados em organizações.

P: Qual é a diferença entre LAN e WAN?

R: LAN abrange uma área geográfica limitada como um edifício, enquanto WAN cobre distâncias maiores conectando múltiplos locais ou cidades.

P: Quais são as principais topologias de rede (Bus, Star, Ring, Mesh)?

R: Bus usa um único cabo backbone, Star centraliza em torno de um hub/switch, Ring conecta nós em círculo e Mesh fornece interconexões redundantes entre todos os nós.

P: Qual é a diferença entre topologia física e lógica?

R: A topologia física descreve o layout real de cabos/dispositivos, enquanto a topologia lógica define como os dados fluem pela rede independentemente das conexões físicas.

P: Quais são as 7 camadas do modelo OSI e suas funções?

R: Física (cabeamento/sinais), Enlace de Dados (frames/MAC), Rede (pacotes/roteamento), Transporte (segmentos/confiabilidade), Sessão (conexões), Apresentação (criptografia/formatação), Aplicação (interfaces do usuário).

P: O que acontece em cada camada durante a transmissão de dados?

R: Os dados são encapsulados para baixo adicionando cabeçalhos em cada camada durante a transmissão e desencapsulados para cima removendo cabeçalhos na extremidade receptora.

P: O que são encapsulamento e desencapsulamento?

R: O encapsulamento adiciona cabeçalhos/rodapés de protocolo conforme os dados descem pelas camadas, enquanto o desencapsulamento os remove conforme os dados sobem pelas camadas no destino.

P: Quais são as 4 camadas do modelo TCP/IP?

R: Interface de Rede, Internet, Transporte e Aplicação, correspondendo às camadas física/enlace de dados combinadas, rede, transporte e sessão/apresentação/aplicação do OSI.

P: Como o TCP/IP se compara ao modelo OSI?

R: O TCP/IP condensa as 7 camadas do OSI em 4 camadas práticas, sendo o TCP/IP focado em implementação enquanto o OSI serve como estrutura teórica de referência.

Protocolos e Transmissão

P: Quais são os principais protocolos de rede (HTTP, HTTPS, FTP, SSH, DNS, DHCP)?

R: HTTP/HTTPS para tráfego web, FTP para transferência de arquivos, SSH para acesso remoto seguro, DNS para resolução de nomes e DHCP para atribuição automática de endereços IP.

P: Qual é a diferença entre TCP e UDP?

R: TCP é orientado a conexão com entrega garantida e ordenamento, enquanto UDP é sem conexão com transmissão mais rápida porém não confiável e sem garantias.

P: Quais são os diferentes tipos de meios de transmissão (com fio vs sem fio)?

R: Com fio inclui cabos de cobre par trançado e fibra óptica, enquanto sem fio usa ondas de rádio incluindo Wi-Fi, celular e tecnologias de micro-ondas.

P: Qual é o papel de um Hub, Switch, Roteador e Firewall?

R: Hubs transmitem tráfego indiscriminadamente, switches direcionam frames por endereços MAC, roteadores encaminham pacotes entre redes e firewalls filtram tráfego por regras.

P: Qual é a diferença entre dispositivos de Camada 2 e Camada 3?

R: Dispositivos de Camada 2 encaminham frames usando endereços MAC, enquanto dispositivos de Camada 3 roteiam pacotes usando endereços IP entre redes.

P: O que é uma VLAN e por que ela é usada?

R: Uma Virtual Local Area Network segmenta logicamente domínios de broadcast em um único switch para maior segurança, desempenho e gerenciamento de tráfego.

P: O que é a marcação 802.1Q?

R: O IEEE 802.1Q adiciona uma tag de 4 bytes aos frames Ethernet identificando a associação à VLAN para links trunk que transportam múltiplas VLANs.

P: O que são ataques de VLAN hopping e como preveni-los?

R: VLAN hopping permite acesso não autorizado entre VLANs via spoofing de switch ou double-tagging; previna desabilitando auto-trunking e limitando o uso da VLAN nativa.

P: O que é roteamento Inter-VLAN?

R: O roteamento Inter-VLAN permite comunicação entre diferentes VLANs usando um roteador ou switch de Camada 3 atuando como gateway entre redes segmentadas.

P: O que é um endereço MAC e como ele é estruturado?

R: Um endereço Media Access Control é um identificador de hardware único de 48 bits formatado como seis pares hexadecimais separando o OUI da porção específica do dispositivo.

P: Qual é a diferença entre as porções OUI e específica da NIC?

R: Os primeiros 24 bits (OUI) identificam o fabricante, enquanto os últimos 24 bits identificam exclusivamente a placa de interface de rede individual.

P: Quais são os endereços MAC especiais (broadcast, multicast)?

R: O broadcast FF:FF:FF:FF:FF:FF alcança todos os dispositivos, enquanto endereços multicast direcionam a grupos específicos e unicast direciona a um único destino.

P: O que é um endereço IPv4 e seu formato?

R: Um endereço IPv4 é um identificador numérico de 32 bits expresso em notação decimal com pontos como quatro octetos separados por pontos (ex.: 192.168.1.1).

P: Quais são as classes de endereço IP (A, B, C, D, E)?

R: Classe A suporta redes grandes (primeiro bit 0), Classe B médias (primeiros bits 10), Classe C pequenas (primeiros bits 110), Classe D para multicast, Classe E experimental.

P: Quais são os intervalos de IP privados (RFC 1918)?

R: Os intervalos privados incluem 10.0.0.0/8, 172.16.0.0/12 e 192.168.0.0/16, que não podem ser roteados publicamente e requerem NAT para acesso à internet.

P: Quais são os endereços IP especiais (loopback, broadcast)?

R: O loopback 127.0.0.1 testa a pilha TCP/IP local e o broadcast envia para todos os hosts dentro de um segmento de rede.

P: O que é a notação CIDR?

R: A notação Classless Inter-Domain Routing expressa blocos IP usando comprimento de prefixo (ex.: /24) indicando o número de bits na porção de rede.

P: Como calcular sub-redes, hosts por sub-rede e intervalos de rede?

R: A quantidade de sub-redes é igual a $2^{(\text{bits emprestados})}$, hosts por sub-rede é igual a $2^{(\text{bits de host})}-2$, e os intervalos são determinados incrementando sistematicamente a porção de sub-rede.

P: Como realizar subnetting manualmente?

R: Identifique os bits emprestados, calcule o tamanho do bloco a partir do bit de sub-rede menos significativo e incremente os endereços de rede por esse valor de bloco.

P: O que é ARP e como funciona?

R: O Address Resolution Protocol mapeia endereços IP para endereços MAC transmitindo solicitações via broadcast e armazenando respostas em uma tabela ARP.

P: Quais são as preocupações de segurança com o ARP (ARP spoofing)?

R: O ARP carece de autenticação, permitindo que atacantes falsifiquem mapeamentos MAC-para-IP, possibilitando interceptação man-in-the-middle e ataques de redirecionamento de tráfego.

P: Por que o IPv6 foi desenvolvido e como ele difere do IPv4?

R: O IPv6 foi criado para resolver o esgotamento do IPv4 com endereços de 128 bits, eliminando NAT, com IPsec integrado e estrutura de cabeçalho simplificada.

P: O que são portas bem conhecidas (0-1023)?

R: Portas bem conhecidas são reservadas pelo sistema para serviços padrão como HTTP(80), HTTPS(443), SSH(22), DNS(53) e SMTP(25).

P: O que são portas registradas e portas dinâmicas?

R: Portas registradas (1024-49151) são atribuídas pela IANA para aplicações, enquanto portas dinâmicas/efêmeras (49152-65535) são atribuídas temporariamente pelos clientes.

P: O que é DHCP e qual problema ele resolve?

R: O Dynamic Host Configuration Protocol automatiza a atribuição de endereços IP, evitando erros de configuração manual e gerenciando eficientemente a alocação do pool de endereços.

P: O que é o processo DORA (Discover, Offer, Request, Acknowledgement)?

R: O cliente transmite um Discover, o servidor responde com um Offer, o cliente solicita o endereço oferecido e o servidor confirma completando a atribuição de lease de IP.

P: O que é um lease DHCP e como funciona a renovação?

R: Um lease DHCP é uma atribuição temporária de IP renovada automaticamente em 50% do tempo de lease através de renovação T1 unicast ou rebind T2 broadcast.

P: Quais são os ataques ao DHCP (Servidor Rogue, Starvation)?

R: Ataques de servidor rogue atribuem configurações maliciosas, enquanto starvation esgota o pool de endereços inundando requisições com endereços MAC falsos.

P: O que é DHCP Snooping e como ele protege as redes?

R: O DHCP Snooping distingue portas confiáveis de não confiáveis, bloqueando respostas de servidores rogue e validando a integridade dos pacotes DHCP contra um banco de dados de binding.

P: O que é NAT e por que ele é usado?

R: O Network Address Translation mapeia endereços internos privados para endereços externos públicos, conservando espaço IPv4 e fornecendo ofuscação básica de segurança.

P: Qual é a diferença entre NAT Estático, NAT Dinâmico e PAT?

R: Estático cria mapeamentos permanentes 1:1, Dinâmico atribui endereços de um pool dinamicamente e PAT usa multiplexação de portas muitos:um para máxima conservação.

P: O que é Port Forwarding?

R: Port forwarding redireciona tráfego entrante em uma porta pública específica para um endereço IP privado interno e mapeamento de porta.

P: O que é NAT Traversal (STUN, TURN, ICE)?

R: STUN descobre endereços públicos, TURN retransmite através de servidores intermediários e ICE combina métodos para estabelecer conexões através de NAT.

P: O que é Carrier-Grade NAT (CGNAT)?

R: CGNAT estende o NAT ao nível do ISP, onde múltiplos assinantes compartilham IPs públicos, criando restrições adicionais de endereçamento para usuários finais.

P: O que é DNS e como funciona?

R: O Domain Name System resolve nomes de domínio legíveis por humanos em endereços IP através de consultas hierárquicas em cascata de servidores recursivos a autoritativos.

P: O que é a hierarquia DNS (Root, TLD, Autoritativo)?

R: Servidores root delegam para Top-Level Domains que delegam para servidores de nomes autoritativos contendo registros de recursos reais para domínios específicos.

P: O que é o processo de resolução DNS?

R: O resolver recursivo consulta o root, recebe referência TLD, consulta o TLD, recebe referência autoritativa, consulta o servidor autoritativo retornando a resposta final

armazenada em cache localmente.

P: Quais são os principais tipos de registros DNS (A, AAAA, CNAME, MX, NS, TXT, PTR)?

R: A armazena IPv4, AAAA IPv6, CNAME aliases, MX roteamento de e-mail, NS servidores de nomes, TXT verificação de texto e PTR entradas de pesquisa reversa.

P: Quais são as ameaças de segurança ao DNS (Spoofing, Hijacking, Tunneling)?

R: Spoofing retorna registros falsos, hijacking redireciona domínios para servidores do atacante e tunneling exfiltra dados através de respostas a consultas DNS.

P: O que é DNSSEC e DNS criptografado (DoH, DoT)?

R: DNSSEC assina digitalmente registros garantindo autenticidade, enquanto DoH/DoT criptografam consultas prevenindo ataques de espionagem e modificação.

Autenticação e Serviços de Diretório

P: O que é RADIUS e como funciona?

R: O Remote Authentication Dial-In User Service centraliza a autenticação usando segredos compartilhados e UDP transmitindo credenciais para verificar autorização de acesso.

P: O que é TACACS+ e como ele difere do RADIUS?

R: TACACS+ separa autenticação, autorização e contabilidade via TCP criptografando payloads completos, enquanto RADIUS criptografa apenas senhas e combina AAA.

P: O que é Kerberos e quais ataques o visam?

R: Kerberos fornece autenticação mútua baseada em tickets exigindo KDC; ataques incluem Golden Ticket, Silver Ticket, Pass-the-Ticket e AS-REP Roasting.

P: O que é LDAP e como é usado em redes?

R: O Lightweight Directory Access Protocol consulta bancos de dados de diretório hierárquicos para autenticação de usuários, associações a grupos e gerenciamento centralizado de identidade.

P: Por que o NTP é importante para a segurança?

R: O Network Time Protocol garante sincronização de relógios, essencial para correlação de logs, validação de certificados, timestamps de tickets Kerberos e precisão de análise forense.

P: O que é Syslog e seus níveis de severidade?

R: Syslog coleta e encaminha logs em 8 níveis de severidade, de Emergência(0) a Debug(7), permitindo monitoramento centralizado e investigação de incidentes.

P: O que é um Sistema Autônomo (AS) e ASN?

R: Um Sistema Autônomo é uma rede sob controle administrativo único identificada por um Autonomous System Number único para fins de política de roteamento.

P: O que é BGP e como funciona?

R: O Border Gateway Protocol troca informações de roteamento entre ASes selecionando caminhos ótimos com base em políticas, mantendo tabelas de conectividade global da internet.

P: O que são ataques de BGP hijacking?

R: BGP hijacking anuncia prefixos ilegítimos redirecionando tráfego para redes controladas por atacantes, possibilitando interceptação, interrupção ou vigilância.

P: O que é peering vs transit?

R: Peering troca tráfego diretamente entre redes sem pagamento, enquanto transit compra conectividade upstream acessando alcance mais amplo da internet.

P: O que é um Internet Exchange Point (IXP)?

R: IXPs são instalações físicas onde redes se interconectam para troca eficiente de tráfego local, reduzindo latência e custos de transit através de peering direto.

P: O que é uma CDN e como o Anycast funciona?

R: Content Delivery Networks armazenam conteúdo em cache geograficamente, enquanto Anycast roteia usuários para o IP idêntico mais próximo anunciado simultaneamente de múltiplos locais.

P: Quais são as bandas de frequência Wi-Fi (2,4 GHz, 5 GHz, 6 GHz)?

R: 2,4GHz oferece alcance com congestionamento, 5GHz fornece equilíbrio entre velocidade e melhor penetração, e 6GHz entrega máximo throughput com alcance limitado.

P: Quais são os padrões Wi-Fi (802.11a/b/g/n/ac/ax)?

R: Os padrões evoluem dos legados 802.11a/b, passando por melhorias g/n, até ac(WiFi5) e ax(WiFi6) oferecendo velocidades crescentes e ganhos de eficiência.

P: Qual é a diferença entre WEP, WPA, WPA2 e WPA3?

R: WEP usa RC4 comprometido, WPA introduziu TKIP, WPA2 exige AES-CCMP e WPA3 adiciona Simultaneous Authentication Equals com proteção de sigilo futuro.

P: Quais são os ataques sem fio comuns (Evil Twin, Deauth, KRACK)?

R: Evil Twin imita APs legítimos, floods de desautenticação desconectam clientes forçando reconexão e KRACK explora falhas de reinstalação de chave no handshake WPA2.

P: Quais são as melhores práticas de segurança sem fio?

R: Use WPA3 quando disponível, senhas fortes, desabilite WPS, separe SSIDs, monitore APs rogue e habilite autenticação Enterprise 802.1X.

P: Qual é a diferença entre autenticação PSK e Enterprise?

R: PSK usa chaves pré-compartilhadas vulneráveis a comprometimento, enquanto Enterprise utiliza RADIUS autenticando cada usuário individualmente com certificados ou credenciais.

Princípios de Segurança e Defesa

P: O que é a Tríade CIA (Confidencialidade, Integridade, Disponibilidade)?

R: Confidencialidade previne divulgação não autorizada, Integridade garante precisão e confiabilidade dos dados, e Disponibilidade assegura recursos acessíveis quando necessário.

P: O que é Defesa em Profundidade?

R: Defesa em Profundidade aplica múltiplos controles de segurança em camadas abrangendo pessoas, processos e tecnologia, garantindo prevenção de brechas mesmo se controles individuais falharem.

P: Quais são os principais princípios de segurança (Least Privilege, Zero Trust)?

R: Least Privilege concede direitos de acesso mínimos necessários, enquanto Zero Trust assume ausência de confiança implícita exigindo verificação contínua de cada requisição.

P: O que é AAA (Autenticação, Autorização, Contabilidade)?

R: Autenticação verifica identidade, Autorização concede permissões e Contabilidade rastreia ações do usuário para responsabilização e conformidade de auditoria.

P: Quais são as principais categorias de ataque (Reconhecimento, Interceptação, DoS)?

R: Reconhecimento coleta inteligência, Interceptação modifica/captura dados em trânsito e Negação de Serviço sobrecarrega recursos impedindo acesso legítimo.

P: O que é um ataque Man-in-the-Middle (MitM)?

R: MitM posiciona atacantes entre partes que se comunicam, interceptando, modificando ou injetando mensagens sem que nenhuma das partes detecte a manipulação.

P: O que são ataques DDoS (Volumétrico, de Protocolo, de Aplicação)?

R: Volumétrico inunda a largura de banda, de Protocolo esgota tabelas de estado da infraestrutura e de Aplicação visa endpoints com uso intensivo de recursos esgotando a capacidade do servidor.

P: Quais são os ataques comuns a senhas?

R: Força bruta tenta combinações, dicionário usa listas de palavras, rainbow tables usam hashes pré-computados e credential stuffing reutiliza credenciais vazadas.

P: Quais são os tipos de firewalls (Filtragem de Pacotes, Stateful, NGFW)?

R: Filtros de pacotes verificam pacotes individuais, stateful rastreiam contexto de conexão e Next-Gen Firewalls adicionam inspeção profunda, IDS e reconhecimento de aplicações.

P: Como escrever regras de firewall?

R: Defina origem, destino, porta, protocolo e ação de permitir/negar; a ordem importa, colocando regras específicas antes das gerais com negação implícita de tudo como padrão.

P: O que é uma DMZ?

R: A Zona Desmilitarizada isola servidores voltados ao público das redes internas, limitando movimentação lateral caso sistemas de perímetro sejam comprometidos.

P: Qual é a diferença entre IDS e IPS?

R: Sistemas de Detecção de Intrusão alertam sobre atividades suspeitas, enquanto Sistemas de Prevenção de Intrusão bloqueiam ativamente ameaças detectadas em linha com o fluxo de tráfego.

P: Quais são os métodos de detecção (Assinatura, Anomalia, Heurística)?

R: Assinaturas correspondem a padrões conhecidos, anomalias identificam desvios do comportamento de linha de base e heurísticas aplicam lógica baseada em regras para detectar indicadores de ameaças novas.

P: O que é segmentação de rede e por que é importante?

R: Segmentação divide redes em zonas isoladas contendo brechas, limitando movimentação lateral e aplicando limites granulares de política de segurança.

P: O que é arquitetura Zero Trust?

R: Zero Trust exige verificação explícita para cada requisição de acesso independentemente da localização na rede, implementando microssegmentação, monitoramento contínuo e autenticação multifator.

P: O que é um SIEM e quais logs devem ser monitorados?

R: O Security Information and Event Management agrega, correlaciona e analisa logs continuamente de firewalls, endpoints, sistemas de autenticação e componentes de infraestrutura crítica.

P: O que é NAC (Network Access Control)?

R: Network Access Control valida conformidade, identidade e postura de saúde do dispositivo antes de conceder acesso à rede, bloqueando endpoints não conformes.

P: O que é autenticação 802.1X e os métodos EAP?

R: 802.1X fornece controle de acesso à rede baseado em porta usando variantes do Extensible Authentication Protocol, incluindo PEAP, EAP-TLS e EAP-TTLS.

Varredura e Enumeração

P: Quais são os tipos de varredura de porta (TCP Connect, SYN, UDP)?

R: TCP Connect completa handshakes de três vias, SYN envia flags sem conclusão sendo mais furtivo e UDP sonda serviços UDP abertos/fechados/filtrados.

P: Quais são os estados de porta (Open, Closed, Filtered)?

R: Open aceita conexões, Closed rejeita conexões ativamente e Filtered descarta pacotes silenciosamente deixando o status ambíguo para scanners.

P: Quais protocolos são usados para enumeração de rede (SNMP, NetBIOS, SMB, LDAP)?

R: SNMP extrai informações de dispositivos, NetBIOS enumera compartilhamentos Windows, SMB revela compartilhamentos de arquivos/sessões de usuário e LDAP consulta estruturas de diretório.

P: Como se defender contra reconhecimento?

R: Implemente regras rígidas de firewall, limite serviços expostos, desabilite protocolos desnecessários, registre tentativas de varredura, use IDS e empregue honeytokens e honeypots.

Fundamentos de Criptografia

P: O que é criptografia em segurança cibernética?

R: A ciência de proteger dados através de algoritmos matemáticos que convertem informações legíveis em formatos ilegíveis para proteger confidencialidade, integridade e autenticidade.

P: Quais são os diferentes tipos de criptografia?

R: Criptografia simétrica (chave compartilhada única), criptografia assimétrica (pares de chaves pública-privada) e hashing criptográfico (funções de mão única).

P: O que é Criptografia (Encryption)?

R: O processo de transformar texto simples em texto cifrado usando um algoritmo e uma chave, tornando os dados ilegíveis sem a chave de descriptografia apropriada.

P: O que é Descriptografia (Decryption)?

R: O processo inverso de converter texto cifrado de volta em texto simples legível usando a chave criptográfica correta.

P: Qual é a importância da criptografia?

R: Ela protege dados sensíveis em repouso e em trânsito, garante autenticação, previne adulteração e mantém conformidade regulatória em sistemas digitais.

P: Quais são os tipos de criptografia?

R: A criptografia simétrica usa uma chave secreta compartilhada, a assimétrica usa pares de chaves pública-privada matematicamente vinculados e o hashing produz digests irreversíveis de comprimento fixo para verificação de integridade.

P: Quais são as aplicações da criptografia?

R: Comunicações seguras (TLS/SSL), criptografia de disco, assinaturas digitais, criptomoeda/blockchain, sistemas de autenticação, tunelamento VPN e protocolos seguros de troca de chaves.

P: O que é um algoritmo de hash?

R: Uma função matemática de mão única que converte entrada de comprimento arbitrário em uma saída determinística de comprimento fixo usada para verificações de integridade e armazenamento de senhas sem descryptografia reversível.

P: O que significa SHA?

R: Secure Hash Algorithm, uma família de funções de hash criptográfico publicadas pelo NIST produzindo digests de comprimentos variados em bits (SHA-1, SHA-256, SHA-512, etc.).

P: O que é John the Ripper?

R: Uma ferramenta de quebra de senhas de código aberto que recupera senhas de formatos com hash usando ataques de dicionário, força bruta e transformações baseadas em regras.

P: Como usar o John the Ripper?

R: Execute john contra um arquivo de hash especificando o formato com --format=, lista de palavras opcional com --wordlist= e regras com --rules; senhas quebradas são exibidas via --show.

P: Como quebrar hashes avançados com o John the Ripper?

R: Especifique o formato exato do hash, aplique conjuntos de regras agressivos (--rules=jumbo), use listas de palavras grandes/personalizadas, habilite o modo incremental e utilize dynamic magic para detecção automática.

P: O que é hashcat?

R: Uma ferramenta de recuperação de senhas de alto desempenho que utiliza aceleração de GPU para quebrar hashes significativamente mais rápido que ferramentas baseadas em CPU, suportando centenas de tipos de hash e múltiplos modos de ataque.

P: Como usar o hashcat?

R: Execute hashcat com o arquivo de hash, identificador do tipo de hash (-m #), modo de ataque (-a #) e caminho da lista de palavras/máscara; resultados quebrados são exibidos com --show.

Autenticação vs Autorização

Conceitos Gerais

P: Qual é o propósito da autenticação em segur